30-DAY ACTION EDITION · 2026



Small Business AI & Cyber Hygiene Blueprint

The practical defense manual for owners, freelancers and small teams. No IT department required.

AI data privacy | Phishing & payment fraud | Two-factor login | Tested backups

10 action pages · Clickable checklists · Fill-in policy & contact sheet

Edition 1.0

START HERE

How to use this blueprint

TIME 5 min | WHO Owner

Four habits stop most attacks on small businesses: guard what goes into AI tools, slow down on suspicious messages, turn on two-step login, and keep backups you have actually tested. Each page below turns one job into a short explanation and a checklist you can tick right in this PDF.

Three rules for working through it

1. **One page, one job.** Read the explanation, then work the checklist. Don't try to do everything in a day.
2. **Tick as you go.** The boxes are clickable in most PDF readers (Acrobat, Chrome, Edge, Preview), or print the pages and use a pen.
3. **Date what you skip.** If a step doesn't fit your business yet, note why and when you'll revisit it. Skipping on purpose is fine; forgetting is the risk.

What's inside

PAGE	TOPIC	TIME
1	Why you are a target, and your 30-day plan	10 min
2	Take inventory: accounts, devices, data and AI tools	1 hour
3	AI data privacy: what never goes into an AI tool	30 min
4	Choosing AI tools safely + one-page AI use policy	45 min
5	Phishing prevention: spotting fake messages	45 min
6	Payment and wire fraud: verification rules	30 min
7	Two-factor authentication: which accounts first, and how	1–2 hours
8	Passwords and password managers	1–2 hours
9	Secure backups: the 3-2-1 rule and restore testing	1–2 hours
10	Incident plan and maintenance calendar	30 min

SHORT ON TIME? DO THESE FIVE TODAY (ABOUT 60 MINUTES)

- [ ] Turn on two-factor login for your business email (page 7).
- [ ] Turn on two-factor login for your business bank account (page 7).
- [ ] Tell whoever pays bills: **bank-detail changes are always confirmed by phone** (page 6).
- [ ] Switch off "use my data to train the model" in every AI tool you use (page 3).
- [ ] Confirm your files back up automatically somewhere other than your laptop (page 9).

PAGE 01

Why you are a target, and your 30-day plan

TIME 10 min | WHO Owner

Criminals target small businesses because they hold money, customer data and bank access, but rarely have a security team. Most attacks are not clever hacking. They are a convincing email, a reused password, or an employee pasting private data into the wrong tool.

88%

of small and mid-sized business breaches involved ransomware, versus 39% at large companies.

Verizon 2025 Data Breach Investigations Report

$3.05B

lost to business email compromise (fake invoices, spoofed bosses) reported to the FBI in 2025.

FBI IC3 2025 Internet Crime Report

24,768

business email compromise complaints filed with the FBI in 2025: about $123,000 lost per complaint.

FBI IC3 2025 Internet Crime Report

AI made this worse in two ways. Scammers now use AI to write flawless emails and even clone a familiar voice on the phone. And your own team may be feeding customer or financial data into free AI chatbots without realizing where it goes. The good news: a handful of basic habits block the large majority of these attacks.

Your 30-day plan

WEEK	FOCUS	PAGES	TIME
Week 1	Take inventory; turn on 2FA for your most important accounts	2, 7	2–3 hours
Week 2	Roll out a password manager; set your AI use rules	3, 4, 8	2–3 hours
Week 3	Phishing and payment-fraud training for everyone	5, 6	1.5 hours
Week 4	Set up backups and test a restore; print the incident plan	9, 10	2–3 hours

Owner's commitment

- [ ] Block time on my calendar for each of the four weeks.
- [ ] Name one person (it can be me) as our **security lead**: _____
- [ ] Tell the team this is a priority, and why.
- [ ] Write down the name and number of an outside IT or security helper, even if we never call them (page 10).

PAGE 02

Take inventory: accounts, devices, data and AI tools

TIME 1 hour | WHO Owner or office manager

You can't protect what you haven't listed. Fill in this inventory in one sitting. Keep it somewhere private: it is a map of your business that you don't want an attacker to find.

ITEM	EXAMPLES	WHICH ONES WE USE	2FA ON?	WHO HAS ACCESS
Email	Google Workspace, Microsoft 365			
Banking & payments	Business bank, Stripe, Square, PayPal			
Accounting & payroll	QuickBooks, Xero, Gusto, ADP			
Website & domain	Domain registrar, Shopify, WordPress host			
Customer data	CRM, booking system, spreadsheets			
AI tools	ChatGPT, Claude, Gemini, Copilot, AI inside other apps			
Devices	Laptops, phones, tablets, card terminals			

Checklist

- [ ] List every business account, **including ones created with a personal email address**.
- [ ] List every device that touches business data, including personal phones used for work email.
- [ ] Ask each person which AI tools they use for work. Make it no-blame: you just need an honest list.
- [ ] Circle your **crown jewels**: the 3–5 accounts that would hurt most if stolen (usually email, bank, payroll, domain).
- [ ] Remove access for former employees, contractors and vendors you no longer use.
- [ ] Turn on automatic updates on every computer, phone and web browser.
- [ ] Check that every laptop and phone has a screen lock and encryption: FileVault (Mac), BitLocker or Device Encryption (Windows). Modern iPhones and Androids encrypt automatically once a passcode is set.

> **DONE WHEN** you have a written list of accounts, devices and AI tools, and your crown jewels are marked.

PAGE 03

AI data privacy: what never goes into an AI tool

TIME 30 min | WHO Everyone

Treat anything you type into an AI tool as if you were emailing it to a company you haven't vetted. Depending on the product and its settings, your prompts may be stored, reviewed by staff, or used to train future models. Free and personal accounts usually offer the least protection.

The traffic-light rule

LIGHT	WHAT IT COVERS	ALLOWED IN AI TOOLS?
RED	Social Security numbers, bank and card numbers, passwords, medical or health records, client files under NDA, employee HR records	**Never**, in any AI tool
YELLOW	Customer names and emails, contracts, financial reports, unreleased pricing, internal strategy	**Only** in an approved business AI account (page 4), and only what the task needs
GREEN	Public website copy, generic marketing drafts, general how-to questions, anonymized examples	**Yes**, in any approved tool

BEFORE YOU PASTE, ASK

1. Would I be comfortable if this exact text appeared in a news story?
2. Can I remove names, numbers and identifying details and still get the help I need?
3. Am I using our approved business account, not a personal one?

Checklist

- [ ] Share the traffic-light table with every employee and contractor (or print it for the wall).
- [ ] In each AI tool, open the privacy or data settings and turn off "use my data to improve the model" (or similar) where offered.
- [ ] Turn off or limit chat history and "memory" features on work accounts if you don't need them.
- [ ] Swap real details for placeholders: "Customer A," "$X," "[address]."
- [ ] Never upload whole customer lists, spreadsheets or contracts to a free AI tool.
- [ ] Check which AI features are switched on inside tools you already pay for (email, CRM, accounting).
- [ ] In health care, finance, legal or education? Ask your compliance advisor before using AI with client data.

PAGE 04

Choosing AI tools safely + your AI use policy

TIME 45 min | WHO Owner

Pick a small number of approved AI tools, pay for business versions wherever customer data is involved, and write the rules down. A short written policy also protects you if a customer, insurer or regulator asks how you handle data.

Questions to ask before approving an AI tool

- [ ] Is there a business or team plan with stronger data terms than the free version?
- [ ] Does the provider state in writing that business data is not used to train its models by default?
- [ ] Can I control how long chats and files are kept, and delete them?
- [ ] Does it support single sign-on or 2FA, plus an admin view of who has access?
- [ ] Does the provider publish security certifications, such as SOC 2 Type II?
- [ ] Handling health data? Will they sign a HIPAA Business Associate Agreement (BAA)?

Our AI Use Policy

Fill in, sign, and have every employee read it.

1. Approved tools	Only these, using company accounts: _____
2. Never enter	Anything in the RED category on page 3.
3. Check the output	AI makes confident mistakes. A person reviews facts, numbers, legal wording and anything sent to a customer.
4. Be honest	We don't pass off AI content as someone's personal work where that would mislead a customer.
5. No unapproved add-ons	Don't connect AI tools to email, files or calendar, or install AI browser extensions, without the security lead's OK.
6. Report mistakes fast	Pasted something you shouldn't have? Tell the security lead the same day. Quick reports are never punished.
7. Review	Reviewed every 6 months. Next review date: _____

Signed (owner) _____ Date _____

Rollout checklist

- [ ] Choose approved tools; stop using personal AI accounts for work tasks.
- [ ] Fill in and sign the policy; have every employee acknowledge it in writing.
- [ ] Review which apps can access your email and cloud files (in your Google or Microsoft account security settings) and remove anything you don't recognize.

PAGE 05

Phishing prevention: spotting fake messages

TIME 45 min | WHO Everyone

Phishing is any message designed to make you click, log in, pay or share something. Spelling mistakes are no longer a reliable clue: AI writes polished emails and texts. **Judge the request, not the writing.**

THE 5 RED FLAGS. ANY ONE IS ENOUGH TO STOP.

1	**Urgency or fear**	"Your account closes today." "Pay now to avoid penalties."
2	**A change in routine**	New bank details, a new way to pay, or a request to keep it quiet.
3	**A login link**	Any message that asks you to sign in through a link it provides.
4	**Unusual payment**	Gift cards, crypto, or a wire transfer to a new account.
5	**A mismatch**	The real sender address, link destination or QR code doesn't match who it claims to be.

AI-era scams to watch for

Voice clones	A call that sounds like the owner or a vendor, urgently asking for money. Hang up and call back on a number you already have.
Deepfake video calls	A "manager" on video asking for a transfer. Verify through a second channel.
QR code phishing	Codes in emails, letters or stickers that lead to fake login pages.
Look-alike alerts	Fake invoices and "security alerts" from tools you really use: Microsoft, Google, Amazon, your bank.

The STOP routine for every employee

S
Stop
Don't click, reply or pay.

T
Think
Does it match a red flag?

O
Open it yourself
Type the address or use the official app.

P
Phone to confirm
Use contact details you already have.

Checklist

- [ ] Turn on the built-in spam, phishing and attachment protection in Google Workspace or Microsoft 365.
- [ ] Add an "External" warning banner to emails from outside your company (an admin setting in both).
- [ ] Set up SPF, DKIM and DMARC on your domain (your email provider or IT helper can do it). It stops others sending email as you.
- [ ] Agree on how to report a suspicious message: forward it to the security lead, or use the report button.
- [ ] Run a 30-minute team session using real suspicious messages from your own inboxes.
- [ ] Thank people who report, even false alarms. Reporting is the habit you want.

PAGE 06

Payment and wire fraud: verification rules

TIME 30 min | WHO Owner + whoever pays bills

Business email compromise, where a criminal poses as a boss, vendor or customer to redirect a payment, cost victims who reported to the FBI about $3 billion in 2025. Wired money is often gone within hours. Written rules, followed every single time, are your defense.

YOUR FIVE PAYMENT RULES (ADOPT ALL OF THEM)

1	**Call-back rule**	Any new or changed bank details are confirmed **by phone**, using a number from your own records, never one from the email or invoice.
2	**Two-person rule**	Payments over $ _____ need approval from a second person.
3	**No-rush rule**	Urgency is never a reason to skip a step. Real partners will wait an hour.
4	**No gift cards, no crypto**	The company never pays anyone in gift cards or cryptocurrency.
5	**Code word**	Agree on a private word for urgent money requests by phone or video. It defeats voice clones and deepfakes.

Checklist

- [ ] Write the five rules down, set your dollar threshold, and share them with everyone who pays bills.
- [ ] Tell your regular vendors that you verify every bank-detail change by phone.
- [ ] Turn on bank alerts for every outgoing payment and every new payee.
- [ ] Ask your bank about Positive Pay, payee approval and dual approval for transfers.
- [ ] Keep a verified contact sheet (name and phone) for each regular vendor, stored outside email.

IF MONEY ALREADY WENT OUT

1. Call your bank's fraud line **immediately** and ask for a recall. Recalls are most likely to work within the first 72 hours.
2. Report it at **ic3.gov** the same day, with transaction details.
3. Change the email password and check for forwarding rules the criminal may have set up.

PAGE 07

Two-factor authentication (2FA)

TIME 1–2 hours | WHO Owner + each account holder

2FA means a stolen password alone is not enough to get in: the attacker also needs your phone, app or security key. It is the single highest-value step in this guide. Start with your crown jewels and work down the list.

Order of priority

1. **Email**: it can reset every other password
2. **Bank and payment processors**
3. **Payroll and accounting**
4. **Domain registrar and website host**
5. **Password manager** (page 8)
6. **Cloud files, CRM, social media, AI tools**

How to turn it on (any account)

1. Sign in and open **Settings → Security**.
2. Choose **2-step verification** or **passkeys**.
3. Pick the strongest method offered (table below).
4. Save the **backup codes** in your password manager.
5. Add a **second method** so a lost phone doesn't lock you out.

Which 2FA method to choose

METHOD (STRONGEST FIRST)	HOW IT WORKS	STOPS PHISHING?	USE IT FOR
Passkey or hardware security key	Your device, fingerprint or a USB/NFC key confirms it's you	YES	Email, bank, admin accounts
Authenticator app or push prompt	An app (Google or Microsoft Authenticator, or your password manager) gives a code or approval	PARTLY	Everything else
Text message (SMS) code	A code sent to your phone number; vulnerable to SIM-swap scams	NO	Only if nothing better is offered

Checklist

- [ ] 2FA on every crown-jewel account this week.
- [ ] Admin setting: **require** 2FA for every user in Google Workspace or Microsoft 365.
- [ ] Buy two hardware security keys (roughly $25–$60 each) for the owner and anyone who can move money.
- [ ] Ask your mobile carrier to add a PIN or "port-out lock" to company phone numbers.
- [ ] Teach the team: **never approve a login prompt you didn't start, and never read a code out to a caller.**

PAGE 08

Passwords and password managers

TIME 1–2 hours | WHO Owner, then everyone

A password manager creates and remembers a unique, strong password for every account, so one leaked password can't unlock the rest. Business plans also let you share logins safely and cut off access instantly when someone leaves.

PASSWORD RULES THAT MATTER TODAY

Length beats complexity	15+ character passphrases, or let the manager generate 20+ random characters.
Never reuse	Every account gets its own password. Reuse is how one breach becomes ten.
Change for a reason	After a breach or a departure, not on an arbitrary schedule.
Share safely	Never by email, chat or sticky note. Share through the manager's vaults.

Setup checklist

- [ ] Choose a business password manager. Well-known options include 1Password, Bitwarden and Keeper.
- [ ] Create a long, memorable master passphrase, and protect the manager itself with 2FA.
- [ ] Store the recovery key or emergency kit somewhere safe that the owner can reach (a locked drawer or safe).
- [ ] Add your crown-jewel accounts first, and replace any reused password with a generated one.
- [ ] Create shared vaults (for example "Finance," "Marketing") instead of sharing personal logins.
- [ ] Turn on breach and weak-password alerts, and fix anything flagged.
- [ ] Once the manager is in place, stop saving business passwords in web browsers.

Offboarding checklist: the day anyone leaves

- [ ] Disable their email and password-manager accounts the same day.
- [ ] Change the passwords of any shared accounts they used.
- [ ] Remove them from bank, payroll, AI tools and social media admin roles.
- [ ] Collect company devices, or remotely wipe them.

Secure backups: the 3-2-1 rule and restore testing

TIME 1–2 hours, then 15 min per quarter | WHO Owner or IT helper

A backup is your insurance against ransomware, theft, fire and human error, but only if it's separate from your main systems and you've proven you can restore it. **Sync is not backup:** if a file in Dropbox, OneDrive or Google Drive is encrypted or deleted, the sync copies the damage everywhere.

The 3-2-1 rule

3

copies of important data: the original plus two backups.

2

different types of storage, such as a cloud backup service and an external drive.

1

copy offline or locked ("immutable"), so ransomware can't change or delete it.

What to back up, and how

DATA	WHERE IT LIVES	HOW TO BACK IT UP
Email and documents	Microsoft 365, Google Workspace	A third-party backup service for your suite. The built-in recycle bin is not a full backup.
Accounting and payroll	QuickBooks, Xero, Gusto	Scheduled exports, plus the vendor's backup add-on if offered.
Computers	Each laptop and desktop	Cloud backup with version history, plus Time Machine (Mac) or File History (Windows) to an external drive.
Website	Your host or platform	The host's automatic backups, plus a monthly download you keep yourself.
Customer data	CRM, booking system, spreadsheets	Scheduled exports saved to your backup location.

Checklist

- [ ] Turn on automatic daily backups with version history (keep at least 30 days of versions).
- [ ] Make sure backups are encrypted, and protect the backup account with its own strong password and 2FA.
- [ ] Keep one copy offline or locked. If you use an external drive, unplug it after each backup.
- [ ] Decide how long you could survive without each system. That tells you how often to back it up.
- [ ] **Test a restore today**: recover one file and one folder, and time how long it takes. Repeat every quarter.
- [ ] Write each test date and result in the maintenance calendar on page 10.

PAGE 10

When something goes wrong: incident plan

TIME 30 min to prepare | WHO Security lead

Print this page and keep it by the phone. In an incident, the first hour matters most, and nobody thinks clearly under pressure.

FIRST-HOUR STEPS

1. **Don't panic, don't hide it.** Tell the security lead immediately.
2. **Disconnect** the affected computer from Wi-Fi and the network. Don't turn it off or wipe it yet.
3. **Money at risk?** Call your bank's fraud line now to freeze or recall payments.
4. **Change passwords** for affected accounts from a different, clean device, and sign out all sessions.
5. **Write it down:** what happened, when, and what you saw. Screenshots help.
6. **Call for help:** your IT helper, and your cyber insurance hotline (insurers often require early notice).
7. **Report it** at ic3.gov (FBI) and, for identity theft, identitytheft.gov.
8. **Check your duties:** if customer personal data was exposed, state breach-notification laws may require you to tell them. Ask a lawyer.
9. **Restore** from a clean backup once the cause is fixed.

Emergency contacts

ROLE	NAME	PHONE
Security lead		
Outside IT or security help		
Bank fraud line		
Cyber insurance hotline		
Lawyer		

Maintenance calendar

HOW OFTEN	TASKS
Monthly	Confirm updates installed; check backup reports; review bank alerts and new payees.
Quarterly	Test a restore; review who can access crown-jewel accounts; 15-minute phishing refresher.
Every 6 months	Review the AI policy, approved tools and their privacy settings; review apps connected to email and files.
Yearly	Redo the page 2 inventory; review cyber insurance; update contacts; repeat the 30-day plan as a check-up.

KEEP GOING

Free resources and next steps

TIME As needed WHO Owner

You've closed the gaps attackers rely on most. These free, official resources go deeper whenever you're ready.

RESOURCE	WHAT IT'S FOR
CISA Secure Our World cisa.gov/secure-our-world	Plain-language basics from the US cybersecurity agency
FTC Cybersecurity for Small Business ftc.gov/business-guidance/small-businesses/cybersecurity	Free fact sheets and training material for your team
SBA: Strengthen your cybersecurity sba.gov	Small business checklists and planning help
FBI Internet Crime Complaint Center ic3.gov	Report online fraud, especially payment fraud
IdentityTheft.gov identitytheft.gov	Recovery plans after identity theft
ReportFraud.ftc.gov reportfraud.ftc.gov	Report scams and bad business practices

OUTSIDE THE US?

Every habit in this guide works anywhere. Only the reporting links and breach-notification rules are US-specific: swap in your country's equivalents, such as your national cybersecurity agency, fraud-reporting service and data protection authority (in the EU and UK, data breaches may need to be reported under GDPR).

Your next three moves

- [ ] Put the maintenance calendar (page 10) into your own calendar as recurring reminders.
- [ ] Set a date one year from today to repeat the 30-day plan as a check-up.
- [ ] Share pages 3 and 5 with every new hire on their first day.

Sources for figures: Verizon 2025 Data Breach Investigations Report; FBI Internet Crime Complaint Center, 2025 Internet Crime Report. The per-complaint figure is reported business email compromise losses divided by complaints.

Disclaimer: This guide provides general educational information. It is not legal, financial or professional security advice, and following it does not guarantee protection against every attack. Product names are trademarks of their owners and are mentioned as examples only; no endorsement is implied.

© 2026 Small Business AI & Cyber Hygiene Blueprint. Edition 1.0. Licensed for use within the purchaser's own business. Please don't resell or redistribute.